

Securitize Solana SPL ACL Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Farouk

JesJupyter

Ctrus

March 17, 2026

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 4

7 Risk Classification 4

8 Protocol Summary 5

9 Attestation 5

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Securitize on Securitize Solana SPL ACL. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated March 17, 2026, was delivered to Securitize, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Securitize or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 3 days, the Cyfrin team conducted an audit on the Securitize Solana SPL ACL code provided by Securitize. The findings consist of 1 Medium & 2 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Securitize Solana SPL ACL
Repository	bc-solana-spl-acl-sc
Commit	df60662bbc47...
Audit Timeline	Mar 10th - Mar 12th, 2026
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	1	1	0
Low Risk	2	2	0
Informational	6	5	1
Gas Optimizations	1	1	0
Total	10	9	1

6 Audit Scope

The audit scope was limited to:

```
programs/spl-token-access-control/src/instructions/admin/add_authority.rs
programs/spl-token-access-control/src/instructions/admin/change_admin.rs
programs/spl-token-access-control/src/instructions/admin/initialize.rs
programs/spl-token-access-control/src/instructions/admin/pause.rs
programs/spl-token-access-control/src/instructions/admin/remove_authority.rs
programs/spl-token-access-control/src/instructions/admin/set_authority.rs
programs/spl-token-access-control/src/instructions/admin/unpause.rs
programs/spl-token-access-control/src/instructions/authority/freeze_account.rs
programs/spl-token-access-control/src/instructions/authority/mint_to_checked.rs
programs/spl-token-access-control/src/instructions/authority/thaw_account.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/create_config.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/delete_config.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/freeze_account.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/freeze_permissionless.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/set_authority.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/set_gating_program.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/setup_extra_metas.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/thaw_account.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/thaw_permissionless.rs
programs/spl-token-access-control/src/instructions/cpi/srfc_37/toggle_permissionless.rs
programs/spl-token-access-control/src/instructions/cpi/token_2022/freeze_account.rs
programs/spl-token-access-control/src/instructions/cpi/token_2022/mint_to_checked.rs
programs/spl-token-access-control/src/instructions/cpi/token_2022/set_authority.rs
programs/spl-token-access-control/src/instructions/cpi/token_2022/thaw_account.rs
programs/spl-token-access-control/src/instructions/srfc_37/create_config.rs
programs/spl-token-access-control/src/instructions/srfc_37/delete_config.rs
programs/spl-token-access-control/src/instructions/srfc_37/freeze_permissionless.rs
programs/spl-token-access-control/src/instructions/srfc_37/set_gating_program.rs
programs/spl-token-access-control/src/instructions/srfc_37/setup_extra_metas.rs
programs/spl-token-access-control/src/instructions/srfc_37/thaw_permissionless.rs
programs/spl-token-access-control/src/instructions/srfc_37/toggle_permissionless.rs
programs/spl-token-access-control/src/states/access_control_state.rs
programs/spl-token-access-control/src/constants.rs
programs/spl-token-access-control/src/discriminators.rs
programs/spl-token-access-control/src/lib.rs
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

Securitize SPL Token Access Control is a Solana Anchor program that places an access control layer between Token-2022 mints and their mint and freeze authority operations. The program's custody PDA holds mint and freeze authority on a Token-2022 mint, and minting, freezing and thawing are performed through the program, which signs the downstream CPI calls.

The program supports two freeze authority modes:

- **Direct mode:** the custody PDA holds freeze authority on the Token-2022 mint and signs freeze and thaw CPIs to Token-2022.
- **Delegated mode:** freeze authority is transferred to a Token-ACL (sRFC-37) mint config account, and the program interacts with the Token-ACL program to freeze and thaw accounts. This mode also supports permissionless freeze and thaw, authorized by an external gating program.

The main components are:

- `access_control_state`: a per-mint PDA that stores the mint's access control configuration and pause flag.
- `access_control_authority`: a per-mint PDA that acts as the signing authority for all CPI calls.
- External programs: Token-2022 for token operations, and Token-ACL for sRFC-37 configuration and permissionless flows.

9 Attestation

Cyfrin attests that it performed a security review of the Securitize Solana SPL ACL code provided by Securitize.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2026-03-17-cyfrin-securitize-solana-spl-acl-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Securitize has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=71a6d73c56883ab8d43acf2d1e6d7c8f973be4d1ba8317f2209500cacb80aa8e
F=2026-03-17-cyfrin-securitize-solana-spl-acl-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.